

Insecure WebSocket Communication

Assessment Identifier: **WS-STA-02** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 6.5	CWE: CWE-319
OWASP: A02	WASC ID: N/A	Confidence: Medium-High candidate
Target / Component: src/services/military-flights.ts	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/src/services/military-flights.ts	Parameter: ws:// endpoint protocol

1. Description

Static analysis identified WebSocket communication using an insecure ws:// connection. Unencrypted WebSocket traffic may be exposed to interception or modification on an untrusted network.

2. Steps to Reproduce

- Run the application locally.
- Open the military-flight functionality.
- Inspect browser network connections.
- Check the WebSocket URL.
- Determine whether it uses ws:// rather than wss://.

3. Controlled Proof of Concept

Safe Proof of Concept:

Document the observed connection scheme in the authorized test environment.

// Observed in source:

```
const flightSocket = new WebSocket('ws://' + flightServiceHost + '/stream');
```

// No interception or traffic modification is required.

4. Business & Security Impact

Information transmitted through an unencrypted WebSocket may be observable or modifiable by a network attacker positioned on the communication path.

5. Remediation Recommendations

Primary Fix: Use wss:// with properly configured TLS. Ensure certificates are validated and the server supports secure WebSocket connections.

- Enforce wss:// exclusively for all WebSocket endpoints across all production and staging environments.
- Verify TLS certificate validation is enabled and disallow fallback to plaintext ws:// connections.
- Configure load balancers and reverse proxies to terminate TLS securely for WebSocket sessions.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis

This finding was identified through static analysis of repository source code and configuration files. Per

assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*